

Roles of Contracts and Contract Issues

Modes of Learning

For this module, the following modes of learning will be used:

- Interactive Module
- Textbook Readings
- Online Quizzes
- Media

Introduction

Supply chain management often requires an organization to share a variety of information with suppliers that may be beyond the organization's operational control. Once information is beyond an organization's direct control, the organization must rely on the supplier to protect its data.

Given that hackers often try to compromise a supplier's network to ultimately gain access to the purchasing organization's network, these types of cyberthreats are less obvious despite being much more dangerous. By compromising a supplier's network, hackers can siphon data, undetected, and exploit the system's specific vulnerabilities.

A cybersecurity incident can expose sensitive customer and employee data such as Personally Identifiable Information (PII), healthcare records and financial information, including debit and credit card details. An organization's intellectual property (IP), trade secrets and business plans are also at risk. Because of a cyber incident, an organization may also face significant financial penalties, legal costs, loss of consumer confidence, drops in stock value and reputational harm.

Such incidents can occur despite a purchasing organization implementing stringent internal cybersecurity plans. The key is to ensure that third parties with privileged access are equally diligent.

As you begin this module, please refer to the timeline and make note of any assessments or important dates. If you have any questions, ask your instructor.

Learning Outcomes

Upon completion of this module, you will be able to:

1. Discuss basic criminal law concepts.
2. Examine common criminal laws used in cyberspace.
3. Describe general tort law concepts and common tort law actions in cyberspace.
4. Describe cybersecurity governance and associated documents.

Key Terms & Concepts

Listed below are some important key terms and concepts within this module.

- PIPEDA
- Real Risk

- Ontario PHIPA
- Significant Harm
- Mandatory Breach Notification

Case Study

The likelihood of a cyber incident affecting Canadian organizations is not low—the media reports major cyber incidents nearly weekly. The following two examples describe real incidents and their effect on the targeted organizations.

Target

In November 2013, Target experienced a data breach, exposing roughly 110 million customers' records and at least 40 million customers' payment card data. The breach happened on or around Black Friday, the busiest shopping season of the year.

Target discovered the breach on December 13 and on December 15 hired a forensic team to investigate the breach. However, by then the damage had already been done: 11 gigabytes of data containing the names, mailing addresses, phone numbers, email addresses and payment card information of up to 70 million people had been compromised. By December 18, the story was made public.

Data Breach: The Target Cyberattack

Investigators found that hackers had targeted several of Target's third-party suppliers by sending them phishing emails. All it took was one employee at one of these suppliers to open an email that installed malware on their system, offering information to hackers that allowed them to break into Target's internal network. The third-party supplier involved was Fazio Mechanical, a small heating and air conditioning firm in Pennsylvania.

The malware gleaned login credentials from the portals used by Fazio Mechanical. Hackers then used these credentials as a staging point into Target's internal network: they pushed malicious software to cash registers at more than 1,800 Target stores in the United States. Unfortunately, Target's system did not have sufficient controls in place to limit hackers' access to in-store devices such as point of sale (POS) registers and central servers.

In the wake of the data breach, approximately 140 lawsuits were filed against Target in the United States and Canada. Target agreed to pay its customers \$10 million in damages and nearly \$20 million to MasterCard as part of its settlement terms. Target never revealed publicly all the details about the breach and its related costs. However, a security analyst put the total cost of the breach at \$100–\$450 million, including fines from credit card companies and services for customers, such as free credit card report monitoring.

The company's stock dipped 1.7 per cent in U.S. trading after the breach became public. Target cut its fourth-quarter outlook by 30 cents/share, to a range of \$1.20 to \$1.30 a share, saying that sales had been hurt by consumers slow to forgive the data breach. Despite implementing a renewed cybersecurity program, Target's sales stagnated and its profit margins were hard hit: Target's profits for the fourth fiscal quarter of 2013 were 46 per cent below expected.

The impact of the cyber incident was also felt at the c-suite level. In May 2014, mere months after the data breach, Target's CEO and President was forced to resign; Target became the first major public corporation to oust its CEO due to cybersecurity issues.

The cyber incident likely also contributed to Target's struggles in Canada. It had expanded into Canada in early 2013 and was already struggling to meet customers' expectations vis-à-vis prices and stocks, when news about its massive data breach became public.

Canadian customers' information had also been compromised in the breach, adding to the list of customers' complaints and exacerbating the losses Target had already sustained. It was not long before Target announced that it would close all of its stores in Canada. Target suffered a loss of \$2 billion after two years in Canada (2013–2015).

Review the following figures published in January 2015 about the breaches:

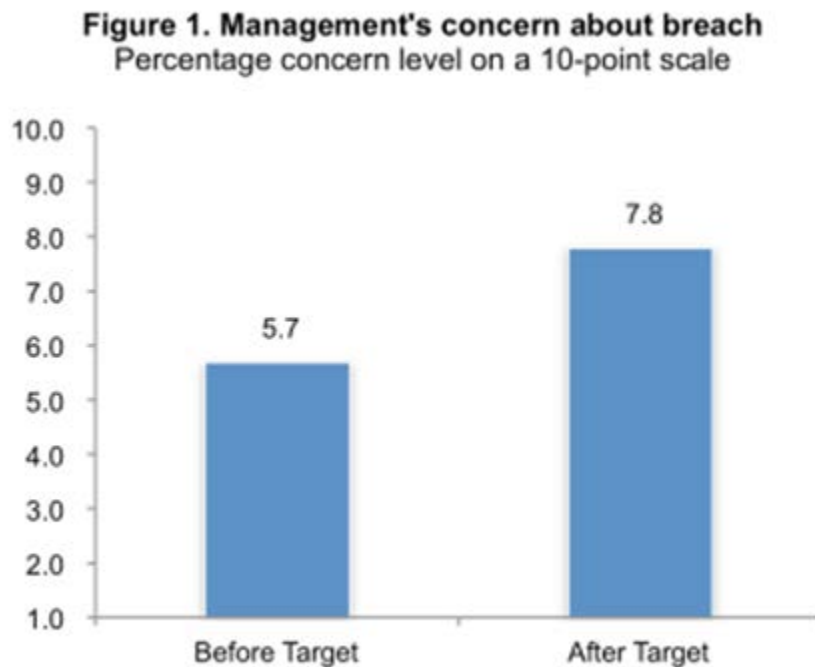


Figure 2. Senior management's concerns about a data breach rose dramatically

Extrapolated value before the Target incident = 5.7, after the Target incident = 7.8

Percentage concern level on a 10-point scale

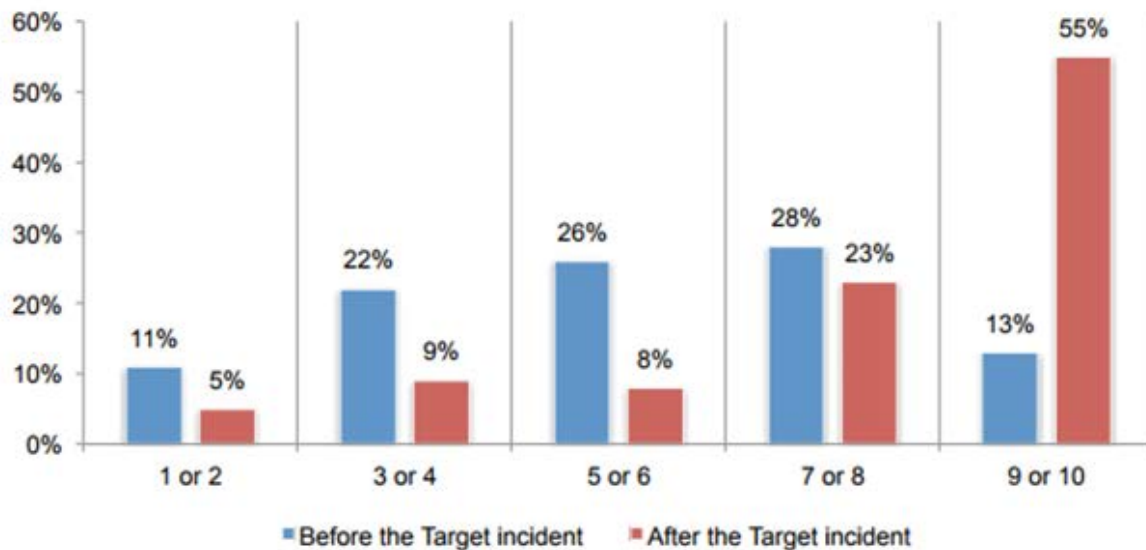


Figure 3. How mega breaches affected respondents' shopping habits

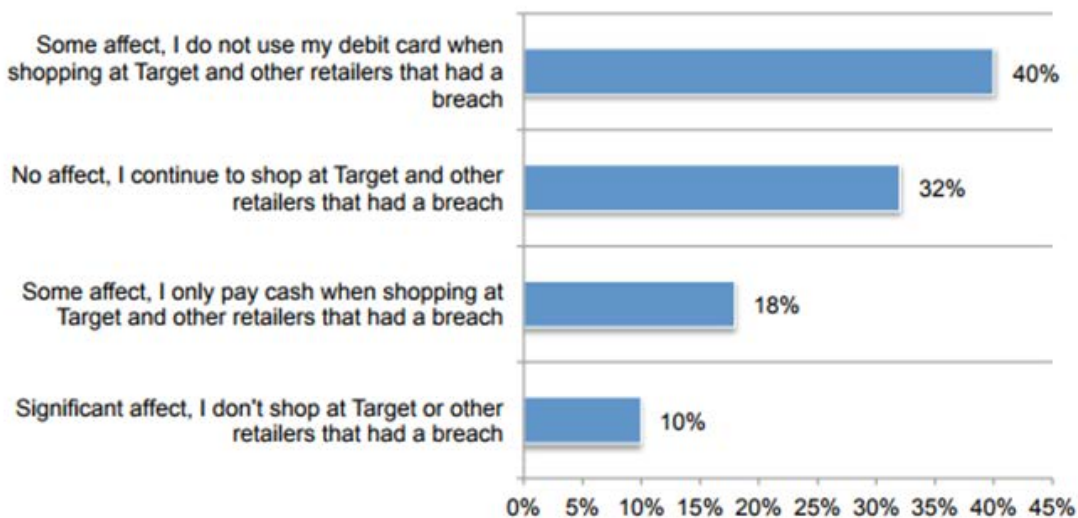
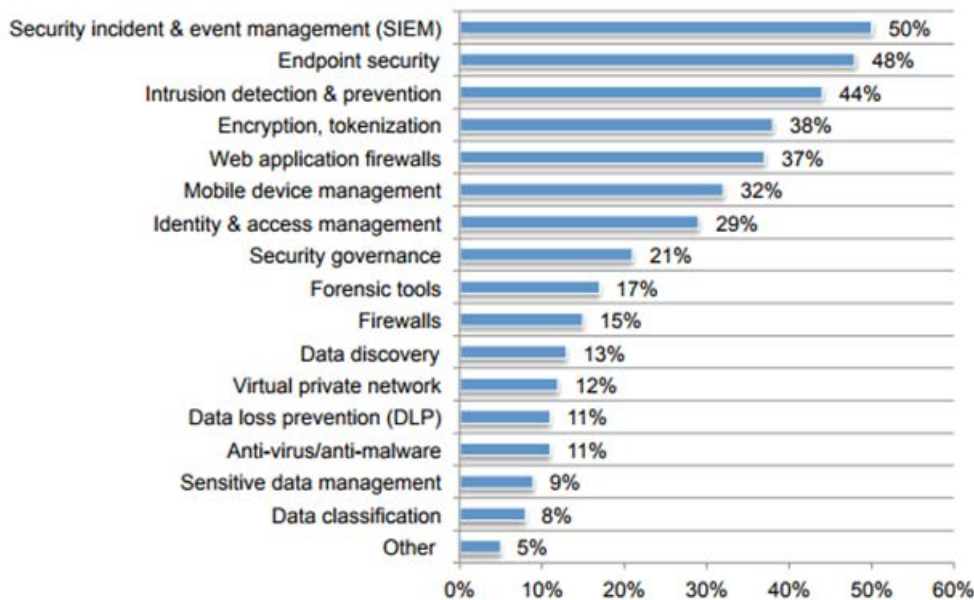


Figure 4. Technology investments made in response to mega breaches



[2014: A Year of Mega Breaches](#)

Home Depot

Home Depot, one of North America's largest retail chains, suffered a similar breach in September 2014: 56 million customers' credit card information and 53 million email addresses were stolen.

The methods employed by hackers were very similar to those used in Target's breach. Hackers entered Home Depot's internal network by using the login credentials of an unidentified third-party supplier. The stolen credentials alone did not provide direct access to the company's POS devices, but the hackers were able to use the initial access to run a privilege escalation attack. This attack, in turn, allowed them to deploy custom-built malware on Home Depot's self-checkout systems in the United States and Canada.

Following the breach, at least 57 lawsuits were filed against Home Depot in the United States and Canada. In March 2016, Home Depot reached a settlement with its U.S. customers, agreeing to pay \$19.5 million to compensate for losses incurred because of the breach. Similarly, in September 2016, Home Depot agreed to pay \$400,000 to Canadian customers whose information had been compromised in the same breach.

In the days following the breach's discovery, Home Depot estimated that its post-breach cleanup costs could be as high as \$62 million, including investigation, credit monitoring service, call centre staffing and other miscellaneous costs. However, the actual number could be much higher, according to a Ponemon Institute report containing an analysis of the average cost of data breach recovery.

Forbes conducted a comprehensive study based on the Ponemon Institute report and estimated that the total cost incurred by Home Depot could have exceeded \$1 billion.

Typical expenses can be classified into the following categories:

Investigation and Remediation

Investigation costs are associated with hiring third-party cybersecurity experts to analyze the extent and impact of the breach. Remediation costs include strengthening cybersecurity protocols.

Home Depot noted \$43 million in pre-tax expenses for investigation and remediation in the third quarter of 2014 alone. In its earnings report following the breach, Home Depot indicated higher investments in information security going forward. The total expense of investigation and remediation is estimated by Forbes to be approximately \$60 per record compromised.

Notification of Individuals

Notifying affected individuals, as well as regulators and media personnel, is labour and resource intensive. Given that 56 million individuals' records were compromised, the cost of notification could be north of \$27 million in postage alone.

Identity Theft Repair, Credit Monitoring

To preserve their reputation, Home Depot offers these services to all customers potentially impacted by a breach; costs could range anywhere between \$400 million and \$850 million.

Disruptions in Normal Business Operations

When management is dealing with the fallout from a data breach, daily operations and/or investments are impacted negatively. Forbes estimates Home Depot's cost for this at \$20 per record.

Lost Business

Data breaches also cause a loss of customers to competitors. Ponemon's research estimates a "high churn rate" at 6 per cent for breach cases in the financial, communication, and health-care industries. Forbes, however, assumes a 3 per cent churn rate for Home Depot, given its duopolistic setup with Lowe's. This brings us to a loss of approximately \$30 per record.

Home Depot

Based on these calculations, Forbes estimates that by the end of the decade, Home Depot will incur a total cost exceeding \$1 billion. It is difficult to ascertain exact costs, given that the damage is long-term and cannot be summed up in the results of one quarter. This is especially true for reputational damage, which is based on intangible data points such as customers' feelings about the breach, and how much they are willing to pay as a result of the breach, instead of switching to a competitor.

Costs

In light of the Home Depot example, supply chain cybersecurity has become a key consideration for organizations looking to ensure that third parties manage shared data securely and that their access to the organization's digital infrastructure is secure.

- Supply chain cyber risks can come from the following:
- Third-party providers' poor information security practices
- Compromised software
- Compromised hardware, e.g. hardware with embedded malware

- Software security vulnerabilities in supply chain management systems
- Counterfeit hardware
- Third-party data stores or aggregators

Consequently, an organization strengthening its own cybersecurity measures is not enough to prevent a breach: hackers can gain access by targeting the organization's network-connected suppliers, who might have weaker cybersecurity measures, and then access the purchaser's systems through authorized channels.

Recommendations for Adopting Cybersecurity Policies

A cybersecurity program must identify all suppliers who collect, use and store sensitive data. In creating a program, the organization must also negotiate and draft a contract that establishes each party's obligations and expectations in handling sensitive data; a well-drafted contract with specific clauses to mitigate cyber risks can go far in preventing and mitigating cyberthreats.

Key considerations for drafting cybersecurity provisions in a supplier contract:

Supplier Management Contract

Understand the purchaser's supplier selection and management program in light of the purchasers' business needs and objectives.

Drafting Approach and Contract Objectives

Cybersecurity provisions in a supplier contract should be drafted so that they remain effective over time while adequately expressing baseline expectations. All parties' cybersecurity goals should be made clear, and costs for these goals should be balanced.

Risk Segmentation

Categorize data and systems based on sensitivity, targeting risk assessments and management protocol for each category.

Information Treatment

The contract should detail the information that the supplier will access, and how that information will be collected, used, stored, shared and destroyed.

Liability

The contract must cover the extent of each party's liability, in the event of a cyber incident.

Supplier Management Context

Purchasers must exercise due diligence when choosing suppliers, based on the context of their industries. Purchasers should also evaluate the capability of prospective suppliers to follow and implement appropriate information security practices for producing/delivering goods and performing services.

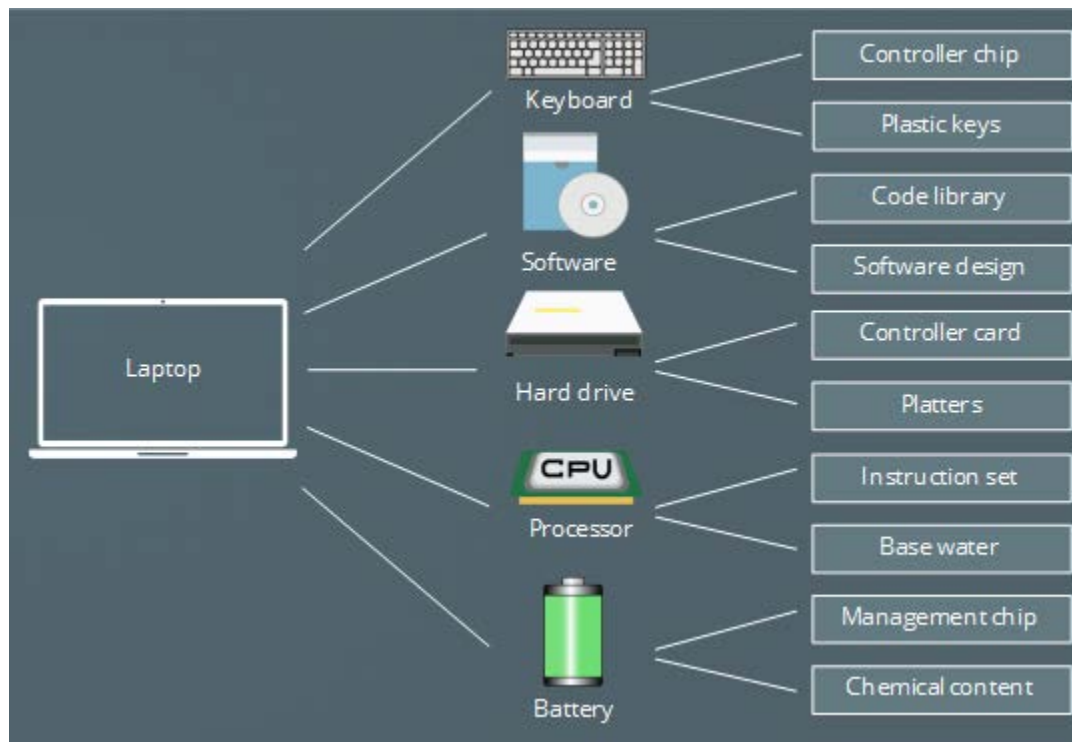
Evaluating a supplier can entail the purchaser conducting a security assessment of the supplier, either directly or through a third party. The assessment should ensure that the prospective supplier has adopted appropriate security policies, incident response procedures and disaster recovery plans; the supplier

should also have processes in place to test and update cyber incident response plans, and to monitor policies regularly.

Internationally recognized cybersecurity standards, such as those developed by the National Institute of Standards and Technology (NIST) or the SANS Institute, can be useful in assessing whether the supplier's cybersecurity measures cover all eventualities and are in line with an industry's best practices. The assessment should also ensure compliance with applicable federal, provincial and sectoral laws.

Consider the supply chain for a typical laptop computer as an example. Laptops are assembled from component parts—a processor chip, a hard drive, plastic and metal casings, etc. However, each part is made of sub-components from sub-tier suppliers. The hard drive, for example, has a motor to spin the drive, memory chips, a controller card, cable connectors, a case, etc., which can all be produced by sub-tier suppliers.

Some of these components and sub-components are commodity items that are often purchased from the lowest cost supplier, and many of these items are manufactured by a contract manufacturer. All of this means that the supply chain can become very complicated, with unknown manufacturers involved.



Before appropriate cybersecurity provisions can be drafted, the purchaser must ensure that it has implemented effective procedures to manage its suppliers.

Step 1

The first step is to identify what impact a breach of the supplier's system would have on the purchaser's day-to-day operations, revenue generation, business and clients.

Step 2

The second step is to establish a primary contact within the purchaser's own organization who will be responsible for:

- Coordinating due diligence on suppliers, using a risk-based approach, and reporting to senior management.
- Maintaining knowledge of and compliance with policies and reporting requirements.
- Filing documentation with the legal and contracting team, to establish a central repository and audit trail.
- Coordinating communication with those who can add value through supplier oversight, e.g. conducting on-site and/or remote audits, reviewing supplier policies and procedures, and monitoring supplier-related litigation or regulatory issues.

Step 3

The third step is for the contact person to ensure that the supplier is also doing its part. At a minimum, that should include:

- A right to audit and test the security controls of suppliers annually (or more frequently if necessary).
- Requiring periodic reports from suppliers, demonstrating security service-level attainment.
- Requiring suppliers to adhere to security monitoring protocols.
- Requiring suppliers to provide timely notification of any security breaches or incidents that may impact the business.

Underlying issues in selecting and managing suppliers

The selection and management of suppliers should be based on the purchaser's understanding of its own business operations.

Underlying issues can be:

1. The purchaser's current cybersecurity management program. For example, a contract provision requiring the supplier to report all cyber incidents can only be used if the purchaser has appropriate channels in place to accept and respond to such notifications.
In Target's case, the organization did not effectively limit suppliers' access to network segments that held customer data. Target was unable to assess its suppliers' security level on an ongoing basis. Target should have required a more robust security guarantee from its suppliers before allowing them to access its network.
2. The purchaser's risk profile for the goods and services exchanged. Is the information to be shared internal operational information, or sensitive customer data? Sensitive data requires a stronger security undertaking from the supplier.

Drafting Approach and Contract Objectives

When drafting cybersecurity provisions in a supplier contract, one key question to ask is to what degree the requirements should be proscriptive. Proscriptive provisions are effective in establishing a security baseline but can be rendered ineffective over time, as they do not account for the evolving nature of cybersecurity threats.

Specific contract provisions can become outdated and insufficient over time, as technology evolves. For example, prior to 2011, NIST recommended that factoring modules' cryptographic keys be 1024 bits in length. In 2011, the standard was increased to 2048, as newer algorithms and faster computers made it likely that 1024-bit keys could be compromised. Therefore, mandating a certain key length will not provide adequate security over time.



Contract provisions should state that suppliers take reasonable steps to keep the purchaser's shared data secure, followed by specific examples of the measures to be taken. Such provisions can and should encompass a broad range of possibilities, without setting limitations on steps that the supplier needs to take. The specific examples can be in the form of industry standards, such as the ones published by NIST, the National Security Agency (NSA), the Department of Defence, or the SANS Institute. Alternatively, organizations can specify examples of security measures that must be in place, e.g. the use of multi-factor authentication or immutable, regularly audited access logs.

A clear understanding of contract objectives can help manage and allocate risk effectively and efficiently. As mentioned earlier, it is important to understand the purchaser's and supplier's business contexts, current practices and legal obligations regarding data.

An analysis of the contract's larger security objectives should follow, to determine what trade-offs need to be made between security and costs. Such trade-offs should be explicitly stated, their potential impact articulated, and appropriate remedies and liabilities determined.

To articulate contract objectives, the purchaser should have a clear understanding of the risks posed by the supplier, which can include:

1. Exchange of customer information, including personally identifiable information.
2. Exchange of trade secrets or intellectual property (IP).
3. Privileged access to systems required by the supplier.
4. Knowledge of the existence and scope of the relationship itself can be a source of risk if it alludes to purchaser's plans.

Given the existence of risks posed by the purchaser-supplier relationships, the contract should include some basic representations and warranties by the supplier. Guidelines from NIST can help articulate such representations and warranties:

1. No recent undisclosed security incidents.

2. No legal claims or regulatory action threatened or pending because of a security incident or vulnerability.
3. Supplier has all licenses, certification and rights necessary and appropriate to provide products, software, data and other information, and perform services as outlined in the contract.
4. No processing, storage or transmission of information to third parties not disclosed to the purchaser.
5. Existence of a regularly updated and well-maintained information security program.
6. Qualified and vetted personnel on supplier's staff, to maintain the information security program.

Both parties need to be pragmatic in assessing the security requirements, based on the sensitivity of the data, nature of the relationship and cost of mitigation. There needs to be a balance between risk mitigation and its impact on performance and cost. For example, if the purchaser is sharing customer PII with the supplier, it would be appropriate for the supplier to adhere to higher cybersecurity standards than they would otherwise.

The purchaser should recognize that implementing such requirements could result in higher costs for the performance of the contract—likely to be passed along to the purchaser. For example, for long-term data storage, NIST recommends higher cybersecurity standards (i.e. stronger cryptographic keys). However, stronger cryptographic keys tend to be costlier. On the other hand, if shared information is only general operational data, such as parts quantities ordered from the supplier per month, then a lower standard of security might be enough.

Contract provisions should clearly allocate risk to either party; an assessment must be made to determine which party can best bear the risk. In determining where to allocate risk, consider the resources available to each party. For example, if the purchaser is sourcing from large suppliers that already have strong data-protection systems and policies in place, the supplier may be better positioned to maintain systems for sharing information.

Similarly, if the supplier is payment card industry (PCI) compliant and stores financial information, it may be better positioned to gather and retain sensitive information. If the data in question is sufficiently sensitive, the supplier's employees might be required to be physically present on the purchaser's premises to access the systems. Such physical presence provisions are often part of the maintenance contracts for computer systems that store personal information for government agencies or large technology companies.

Risk Segmentation

Contract objectives are also affected by the risk profile of each supplier relationship. A risk profile will assess the risks to which each supplier can expose the purchaser, and will be based on the nature of goods or services exchanged, and the dependency and interconnectedness of the contracting parties.

A risk profile is based on:

- The level of interconnectedness.
- The sensitivity of data shared.
- The sensitivity of systems to which access is granted.
- The potential impact on the purchaser's operation if the supplier's systems go offline.

In addition, pertinent questions that need to be answered are:

1. What is the nature of the information to be processed or stored?
2. Do the goods or services exchanged support critical operations?
3. Will the supplier interact directly with the purchaser's customers or have access to them through a system or portal?
4. Will the supplier give access to another supplier downstream? If so, define the protocols around that information sharing.
5. Is supplier subject to special circumstances? Certain countries block secure communication tools such as Virtual Private Networks (VPNs).

The risk profile is different for each supplier and might also be different for various aspects of the supplier relationships. As mentioned earlier, the nature of goods and services exchanged is a primary consideration in building a risk profile.

It is often useful to segment data and systems into tiers of sensitivity and criticality, and then apply consistent controls to each segment. This segmentation can be done for the purchaser's data and systems prior to drafting individual contracts. Having the segmentation analysis ahead of time will save time, as the same data sets are often shared with multiple suppliers. It will also ensure that relationships with multiple suppliers conform to a consistent level of security.

To segment data, we can look at the impact of a data breach on the purchaser's reputation, liability and competitive advantage. This can help identify the level of security required for each data item.

Similarly, for systems, we can segment their sensitivity by analyzing the impact of malicious access, and one way to do this is by answering some crucial questions prior to a breach occurring.

For example, if a malicious actor gains access to the system:

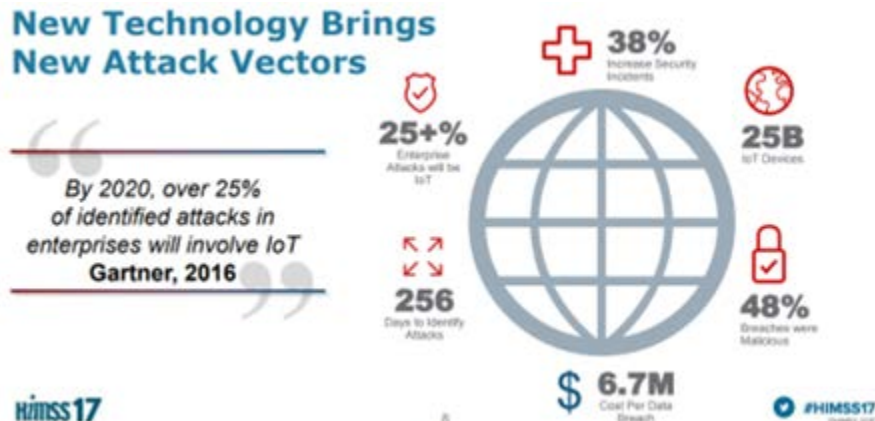
1. What data can they access?
2. What data can they delete or damage?
3. Can they deface purchaser's publicly visible websites?
4. Can they harm purchaser's operations by taking the system offline?
5. Can they make fraudulent transactions using the system?
6. Will malicious actions be traceable and auditable?

The purchaser and the supplier should also discuss the framework for categorizing data; using standard models for risk segmentation—ISO 27001, for example—can be particularly helpful. Data segmentation and risk profiling help the parties draft relevant clauses for each type of data or system to be shared; they are invaluable in balancing security with cost and operational overhead, as purchasers make educated decisions when applying security controls on each data type or system.

Contracting parties should determine the level of access to their systems and information that they will grant each other, based on the risk segment of the information/system and the risk profile ascribed to the supplier relationship.

Access may also be constrained by physical, logical and administrative controls.

- Physical controls can be implemented by limiting access to specific devices, networks or users, and by using multi-factor authentication.
- Logical controls can be implemented by requiring passwords and per-user authentication (i.e., no shared passwords between users).
- Administrative controls consist of policies such as minimum length and character requirements for passwords; a mandatory password-rotation period; taking and auditing of all user actions; and periodic audits of user permissions, to ensure they are updated based on staffing changes. At a minimum, systems should require identity authentication of individual users, processes or devices before allowing access to organization information systems.



Use the Risk Management Framework



Information Systems

Understanding the information life cycle—how information is used, collected, stored and deleted—is also an important consideration when drafting cybersecurity clauses. Contracting parties should consider the following:

Collection

Which party will collect information, and how will it do so securely? Will both parties share confidential information with each other, and will all provisions apply equally to both parties?

Storage

Which party will store information? Will the information need to be encrypted and if so, what level of encryption will be used? Will data sovereignty laws or export controls apply, to limit international

transmission of data? Can data be stored in the cloud, or must it be stored on hardware under the physical control of the supplier? Restrictions on storage locations and notice of storage in undisclosed locations should also be discussed.

Deletion

How long must data be retained, and how it will be destroyed when it is no longer needed? If purchaser information is backed up in a manner that makes destruction impractical, it should also be noted.

Third-Party Access

Will any third party have access to data? The circumstances and conditions under which data will be shared with affiliates and downstream suppliers/subcontractors should be noted. The parties should also discuss protocols and compensating controls of that access.

Permitted Uses

The contract should state how data may be used; protocols should also be in place for accessing data and for preventing its misuse. For example, Apple and Samsung are competitors in the smartphone manufacturing business. However, Samsung also supplies screens to Apple, for iPhones, meaning that Samsung has access to Apple's sensitive business information, including screen requirements, quantities ordered and order delivery dates. Hence, supplier contracts between Apple and Samsung must contain clauses that ensure Samsung does not use the sensitive business information to unfairly compete with Apple.

Risk Allocation upon Loss

How will the purchaser respond if information is compromised by the supplier or any third party? Loss should be allocated to the party responsible, and appropriate remedies should be suggested.

Information to which supplier is given access and how it relates to purchaser's business objectives is important in answering the above questions. Before giving access to its information and systems, purchasers should ensure that its data is protected, used and shared in an appropriate manner. Furthermore, the contract should make sure that expectations around information life cycle management are understood by all parties, and appropriate liabilities and remedies are in place if the expectations are not met.

Liability

Even with the best information security policies, it is not always possible to address all potential cyberthreats. Accordingly, the purchaser–supplier contract should discuss liability in the case of a breach.

In attributing liability, parties should consider the potential scope of damages and expenses from the cyber incident: incidental and consequential damages to the organization from investigation, incident response, customer notifications, and injury to reputation could be substantial.

Incidental damages result directly from a breach. On the other hand, consequential damages flow from the end result of the breach and not from the breach itself; they tend to be indirectly associated with the breach.

Liability clauses should be written so they prevent any one party from avoiding payment by setting up a shell organization to evade it. Financial due diligence can prevent such traps.

In addition, ensuring that parties have appropriate cyber risk insurance can assure both parties. Even if the liable party cannot make the payment, if there is appropriate insurance coverage, it may be able to cover some, or all, of the costs related to a cyber incident.

Additional issues surrounding cyber risk insurance coverage concerns need to be considered addressed. For example:

1. Will insurance cover cyber incidents caused by human error?
2. How much of the damages will be covered?
3. How will compensation differ if the cyber incident was caused despite compliance with the policies and procedures in place?

Liability clauses should state whether a cyber incident will be treated as a strict liability offence. Under strict liability, the party responsible for the incident pays damages even if no harm or negligence is found. If strict liability is not enforced, the contract must describe what constitutes “harm,” since reputational damage can be difficult to quantify.

American courts have taken a fairly liberal view of what constitutes sufficient harm to warrant reparations. In Target’s example, Judge Paul A. Magnuson stated that “unlawful charges, restricted or blocked access to bank accounts, inability to pay other bills, and late payment charges or new card fees” constituted sufficient injury for the plaintiffs to seek reparations.

Force majeure clauses are often used in contracts to address concerns arising from circumstances outside the parties’ control. The first step in adding such clauses is to define what will constitute force majeure. For example, would it cover a breach caused by a criminal or a nation state?

If drafted correctly, such clauses can allow parties to preserve performance and continue business, despite disruptions. In the event of a disaster, the contract can offer solutions such as:

- Retention and back-up procedures.
- Ability and time to fail over to redundant systems.
- Security of back-up facilities to preserve sensitive data and secure information systems.

Having fallback options in the face of crisis can help resolve issues quickly and preserve business relationships.

The contract also needs to specify appropriate exit strategies and penalties for a supplier’s non-compliance with cybersecurity provisions. The exit strategy can be a termination of the relationship. Alternatively, the supplier’s privileged access to the purchaser’s information or systems can be temporarily blocked.

Punitive damages may also be stipulated in the contract, to ensure compliance with its provisions. Furthermore, clauses can be written to allow the purchaser to exit the contract without penalty if the supplier is consistently negligent and non-compliant.

Module Summary

In this module you have learned:

1. It is critical for organizations to protect data and information systems, especially when access is given to third parties. Such access can be a source of vulnerability in an otherwise secure system.
2. Purchasing organizations must understand their own operating landscape and business needs. Appropriate suppliers can then be selected and managed securely.
3. Understanding the risks associated with suppliers and ensuring that contractual clauses include key considerations can help prevent and mitigate damages that follow from such incidents.
4. Contractual clauses can ensure that suppliers follow cybersecurity protocol throughout the supply chain; clauses can help parties create risk profiles, segment data and handle information so that parties are better equipped to respond to threats and incidents.

Knowledge Check

The following questions provide an opportunity for you to see what you remember and understand so far. Answer the questions to the best of your ability.

1. **Supply chain management often requires an organization to share information with suppliers that may be beyond the organization's operational control.**
 - a. True
 - b. False
2. **Before the appropriate cybersecurity provisions can be drafted, the purchaser must establish effective procedures for managing its supplies. The steps include:**
 - a. Identifying the impact that a breach of the supplier's system would have on the purchaser's day-to-day operations, revenue generation, business and clients
 - b. Establishing a primary contact within the purchasing organization, responsible for determining whether the organization must notify third parties if a breach occurs
 - c. Having the primary contact ensure that the supplier is also doing its part
 - d. All of the above
3. **When it comes to protecting information, the purchaser must ensure that third parties with privileged access are as diligent as the purchaser.**
 - a. True
 - b. False
4. **Target's data breach was the result of a highly sophisticated plan to break into their internal network.**
 - a. True
 - b. False
5. **Typical expenses following a data breach can be classified into the following categories:**
 - Investigation and remediation.
 - Notification to individual.
 - Identity theft repair credit monitoring.
 - Disruptions in normal business operations.
 - Lost business.
 - a. True
 - b. False
6. **Supply chain cyber risks cannot come from third-party providers' information security practices.**
 - a. True

- b. False
- 7. A cybersecurity program must identify all suppliers who collect, use and store sensitive data.
 - a. True
 - b. False
- 8. In a supplier contract, there must be a balance between risk mitigation and its impact on performance and cost.
 - a. True
 - b. False
- 9. Proscriptive provisions are effective in establishing a security baseline but can be rendered ineffective over time, as they do not account for the evolving nature of cybersecurity threats.
 - a. True
 - b. False

Answers:

- 1. True
- 2. All of the above
- 3. True
- 4. The answer is false because all it took was one employee at one of Target's suppliers to open a phishing email, installing malware on the supplier's system and gleaning login credentials, which hackers then used to access Target's internal network.
- 5. True
- 6. The answer is false because supply chain cyber risks can come from third-party providers' poor information security practices, compromised software or hardware, software security vulnerabilities in supply chain management systems, counterfeit hardware, hardware with embedded malware, and third-party data stores or aggregators.
- 7. True
- 8. True
- 9. True

You have completed: Roles of Contracts and Contract Issues

Remember to check the timeline before you proceed to the next module to ensure you have completed any assignments as required. Check with your instructor if you have any questions.